

Threat Analysis Report

รายงานวิเคราะห์โครงสร้างพื้นฐานเครือข่ายพรีอ็อกซี
ประเภท Operational Relay Box Network ที่ใช้ชื่อว่า
RedRelay, ORBWEAVER และผู้พัฒนาที่อยู่เบื้องหลัง

02/08/2026

TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
การวิเคราะห์เชิงเทคนิค.....	4
Tactics, Techniques, and Procedures (MITRE ATT&CK)	12
Indicators of Compromise (IoCs)	13
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ	15
อ้างอิง (References).....	17



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์โครงสร้างพื้นฐานเครือข่ายพรีอ็อกซีชอนตัวประเภท Operational Relay Box Network ที่มีรายงานเรียกชื่อไว้สองชื่อคือ RedRelay (ตั้งโดย PwC ปี 2021) และ ORBWEAVER (ตั้งโดย Mandiant ปี 2024) ซึ่งนักวิจัยประเมินว่าน่าจะเป็นเครือข่ายเดียวกันหรือทับซ้อนกันอย่างมีนัยสำคัญ โดย Mandiant ได้จัดประเภท ORBWEAVER ไว้เป็นเครือข่าย ORB ประเภท Non-provisioned network ซึ่งคือเครือข่ายที่ประกอบด้วยอุปกรณ์ Router/IoT ที่ถูกยึดครองหรือหมดอายุการสนับสนุน เครือข่ายนี้มีหน้าที่สำหรับการอำพรางเส้นทางที่ใช้ในการโจมตีของผู้ไม่หวังดีที่ได้รับการสนับสนุนจากรัฐ (State-Sponsor) จากจีน

จากการสืบสวนของกลุ่มนักวิจัยที่เน้นการสืบสวนแบบ open-source investigation ที่ใช้ชื่อว่า "Intrusion Truth" ได้มีการระบุความเชื่อมโยงของเครือข่ายพรีอ็อกซีชอนนี้ว่ามีความเกี่ยวข้องกับ Guangdong Chanming ซึ่งเป็นบริษัทที่แทบไม่มีตัวตนสาธารณะ ไม่มีเว็บไซต์การตลาด แคตตาล็อกผลิตภัณฑ์ด้านความปลอดภัยที่มุ่งสู่ผู้บริโภคทั่วไป แต่สิทธิบัตรและลิขสิทธิ์ซอฟต์แวร์ที่จดทะเบียนกลับบรรยายถึงเครื่องมือที่มีความสามารถสอดคล้องกับการสอดแนม การไม่เปิดเผยตัวตน การเก็บข้อมูล และปฏิบัติการไซเบอร์เชิงรุกมากกว่าผลิตภัณฑ์รักษาความปลอดภัยองค์กรทั่วไป รวมไปถึงมีเอกสารจัดซื้อจัดจ้างของกองทัพจีนที่ระบุว่า Guangdong Chanming เป็นผู้จัดหา "ระบบเครือข่ายนิรนาม" (Anonymous Network System) ให้กับหน่วยงานทหารในเขตไห่เตี้ยน กรุงปักกิ่ง

ระดับความเชื่อมั่นของรายงาน: ข้อมูลส่วนใหญ่ในรายงานฉบับนี้อ้างอิงจากการสืบสวนแบบ open-source intelligence (OSINT) โดยกลุ่มนักวิจัยอิสระ Intrusion Truth ซึ่งประกอบด้วยหลักฐานจากทะเบียนสิทธิบัตร เอกสารจดทะเบียนบริษัท ข้อมูลรั่วไหล และเอกสารจัดซื้อจัดจ้างสาธารณะ ไม่ได้มาจากการรั่วไหลของเอกสารภายในบริษัท Guangdong Chanming โดยตรง หรือการยืนยันจากหน่วยงานภาครัฐ ดังนั้นข้อสรุปหลักในรายงานนี้จึงควรพิจารณาในระดับ "ประเมินด้วยความเชื่อมั่นปานกลางถึงสูง" (Moderate to High Confidence) ไม่ใช่ระดับ "ยืนยันแล้ว" (Confirmed) ทั้งหมด



การวิเคราะห์เชิงเทคนิค

RedRelay

RedRelay เป็นชื่อที่ PwC Threat Intelligence ตั้งขึ้นครั้งแรก โดยระบุไว้ในรายงาน "Cyber Threats 2022: A Year in Retrospect" ว่าเป็นหนึ่งในความสามารถ obfuscation-as-a-service ที่กลุ่มภัยคุกคามจีนใช้เพิ่มขึ้นอย่างต่อเนื่อง ควบคู่กับมัลแวร์และเครื่องมือที่ใช้ร่วมกัน เช่น ShadowPad และ ScanBox

โดย PwC ได้มีการนิยามเครือข่ายนี้ไว้ดังนี้

- PwC เริ่มทำการวิจัยเครือข่ายฟร็อกซี้ตั้งแต่ปี 2021 และเรียกเครือข่ายนี้ว่า "RedRelay" โดยเป็นเครือข่ายที่ใช้ร่วมกันโดยกลุ่มภัยคุกคามหลายกลุ่ม (used by multiple threat actors)
- PwC ประเมินว่าเครือข่ายปกปิดตัวตนเหล่านี้จะดำเนินการในลักษณะข้อตกลงแบบ "quartermastering" ซึ่งเครื่องมือถูกจัดหา ขาย และแบ่งปันโดยหน่วยงานรัฐหรือเอกชนรายหนึ่ง
- ลักษณะของเครือข่ายฟร็อกซี้ประกอบด้วยการทำ multihop proxying และการสื่อสารผ่านช่องทางเข้ารหัส ซึ่งท้าทายวิธีการวิจัยแบบดั้งเดิมสำหรับการวิเคราะห์ และการระบุตัวตนผู้โจมตี (attribution) โดยเครือข่ายฟร็อกซี้เหล่านี้สร้างขึ้นจากการผสมผสานระหว่าง VPS หลายร้อยเครื่องที่ผู้ไม่หวังดีควบคุมอยู่ ร่วมกับอุปกรณ์ที่ถูกยึดครอง

ORBWEAVER

ORBWEAVER (หรือ ORB1) เป็นชื่อที่ Mandiant (Google Cloud) ตั้งขึ้นในปี 2024 สำหรับเครือข่าย ORB (Operational Relay Box) ประเภท Non-provisioned network ซึ่งประกอบด้วยอุปกรณ์ router และ IoT ที่ถูกยึดครองหรือหมดอายุการสนับสนุนแล้ว โดยมี ORB2/FLORAHOX เป็นตัวอย่างในกลุ่มเดียวกัน ต่างจาก Provisioned network ที่ประกอบด้วยพื้นที่ VPS เช่าเชิงพาณิชย์ที่บริหารโดยผู้ดูแล ORB โดยตรง (เช่น ORB3/SPACEHOP)

Mandiant ระบุว่าเซิร์ฟเวอร์ที่ควบคุมโดยผู้ไม่หวังดี (ACOS) และโหนด VPS ที่เช่าจากผู้ให้บริการคลาวด์ (relay node) ส่วนใหญ่ตั้งอยู่ใน IP space ที่เกี่ยวข้องกับจีนและฮ่องกง ส่วนโหนดที่เหลือกระจายอยู่ทั่วโลก



ความเชื่อมโยงระหว่าง RedRelay และ ORBWEAVER

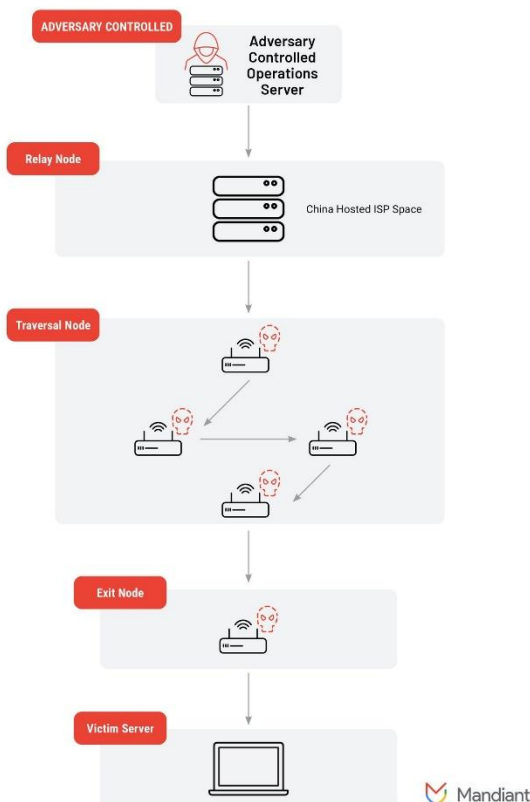
Symantec รายงานในปี 2024 ว่าเครื่องมือ tunneling ชื่อ Whipweave ซึ่งน่าจะพัฒนาต่อจากโปรเจกต์ VPN จีนโอเพนซอร์ส Free Connect (FCN) ถูกใช้เชื่อมต่อเข้ากับเครือข่าย ORB ที่รู้จักในชื่อ Orbweaver ต่อมา Intrusion Truth (2026) ระบุว่า WHIPWEAVE เป็นคอมโพเนนต์หลักของ "เครือข่าย RedRelay (หรือที่รู้จักในชื่อ ORBWEAVER)"

กล่าวคือ **จุดรวมที่ใช้เชื่อมโยงทั้งสองชื่อคือมัลแวร์ WHIPWEAVE** ซึ่งถูกกล่าวถึงในบริบทของทั้งสองชื่อโดยนักวิจัยคนละกลุ่ม ไม่ใช้การยืนยันโดยตรงจาก PwC หรือ Mandiant เอง

สถาปัตยกรรมพื้นฐานของ ORB

Mandiant ได้มีการออกแบบและกำหนดลักษณะส่วนประกอบต่อไปนี้ ซึ่งมีความสำคัญต่อการทำงานของเครือข่าย ORB

- **Adversary Controlled Operations Server (“ACOS”)**: เซิร์ฟเวอร์ที่ควบคุมโดยผู้ไม่หวังดีซึ่งใช้ในการจัดการโหนดภายในเครือข่าย ORB
- **Relay Node**: โหนด VPS ที่เข้าจากผู้ให้บริการคลาวด์รายใหญ่ในจีนหรือฮ่องกง โหนดนี้อำนวยความสะดวกให้ผู้ใช้งานเครือข่าย ORB ยืนยันตัวตนกับเครือข่ายและส่งต่อทราฟฟิกผ่านพูลการเข้าถึงขนาดใหญ่บนโหนด ORB
- **Traversal Nodes**: กลุ่มโหนดหลักที่ประกอบขึ้นเป็นเครือข่าย ORB โหนดเหล่านี้อาจเป็นโหนดที่จัดเตรียมไว้แล้วหรือยังไม่ได้จัดเตรียม และใช้เพื่อส่งต่อทราฟฟิกผ่านเครือข่าย ORB เพื่อปกปิดที่มาของทราฟฟิกเครือข่าย บางเครือข่ายอาจใช้โหนดการส่งผ่านหลายประเภทหรือรวมถึงเลเยอร์การส่งผ่านหลายชั้น
- **Exit/Staging Nodes**: โหนดเหล่านี้เป็นโหนดที่ควบคุมโดยผู้ไม่หวังดี ซึ่งมักมีลักษณะเดียวกันกับโหนดการส่งผ่านที่ใช้เพื่อออกจากเครือข่าย ORB ไปยังสภาพแวดล้อมของเหยื่อ
- **เซิร์ฟเวอร์เหยื่อ**: โครงสร้างพื้นฐานของเหยื่อเป้าหมายที่สื่อสารกับโหนดเครือข่าย ORB



ภาพที่ 1 แผนภาพองค์ประกอบ ORB (ที่มา Mandiant)

เครื่องมือที่เกี่ยวข้องกับการนำไปสู่เครือข่าย

ในการวิเคราะห์ล่าสุด (กรกฎาคม 2026) คือการสืบสวนของ Intrusion Truth ที่เชื่อมโยงเครื่องมือทั้ง 3 เข้าด้วยกัน

1. FCN (Free Connect)

FCN เป็นเครื่องมือ VPN ที่เริ่มต้นเป็นโปรเจกต์เดี่ยวบน GitHub ภายใต้ชื่อผู้ใช้ "boywhp" ซึ่งภายหลังพบว่าคือ Wang Huiping (王慧平) ผู้ร่วมก่อตั้ง Guangdong Chanming แม้ repository ต้นฉบับจะถูกลบไปแล้ว แต่ยังพบร่องรอยใน fork ต่างๆ ที่ชี้ไปยังโดเมน xfconnect[.]com

ลายเซ็นทางเทคนิคที่สำคัญ: แทบทุก Linux build ของ FCN ใช้คำสั่งที่ผิดปกติในการระบุชื่ออินเทอร์เน็ตเฟซเครือข่าย คือ `cat /proc/net/route | awk '{print $1,$2}' | awk '/00000000/{print $1}'` คำสั่งนี้กลายเป็นลายนิ้วมือ (fingerprint) สำคัญในการติดตามโค้ดชุดนี้ข้ามไปยังมัลแวร์ตระกูลอื่น



2. STN (Security Tunnel Net / 防溯源密网系统)

STN เป็นผลิตภัณฑ์เชิงพาณิชย์ของ Guangdong Chanming ที่พัฒนาต่อยอดจาก FCN โดยมีชื่อเดิมภาษาจีนแปลว่า "ระบบเครือข่ายลับด้านการสืบทายแหล่งที่มา"

หลักฐานเชื่อมโยงกับ FCN: STN binary (stn.exe) มีลักษณะคล้ายกับไฟล์ FCN อย่างชัดเจน โดยสตริงที่สกัดออกมาจาก STN มีการอ้างอิงถึง FCN โดยตรง

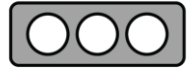
3. WHIPWEAVE (ชื่อไฟล์: bulbature)

WHIPWEAVE ถูกระบุโดยนักวิจัยว่าเป็นคอมโพเนนต์หลักของเครือข่าย RedRelay โดยเป็นเครื่องมือ Tunneling สำหรับเชื่อมต่อเข้าสู่เครือข่ายพรีอ็อกซี ซึ่งพบผ่านการค้นหาหลายชิ้น คำสั่ง Linux เดียวกันกับที่ใช้ใน FCN ทำหน้าที่เป็นคอมโพเนนต์ tunneling หลัก เพื่อปกปิด Command traffic และรองรับปฏิบัติการจารกรรมระยะยาว

Guangdong Chanming

Guangdong Chanming เป็นบริษัทจากจีนที่แทบไม่มีตัวตนสาธารณะ ไม่มีเว็บไซต์ การตลาด แคตตาล็อกผลิตภัณฑ์ด้านความปลอดภัยที่มุ่งสู่ผู้บริโภคทั่วไป แต่มีจุดน่าสนใจคือการยื่นจดสิทธิบัตรและลิขสิทธิ์ซอฟต์แวร์ โดยรายการของซอฟต์แวร์นั้นดูไม่เหมือนจะไม่ใช้ผลิตภัณฑ์สำหรับผู้บริโภคทั่วไป และแต่ละรายการดูเป็นซอฟต์แวร์ที่ดูอันตรายทั้งสิ้น

- 互联网安全接入系统 – Internet Security Access System
- 多功能安全代理系统 – Multi functional Security Proxy System
- 文件传输密网系统 – File Transfer Network System (FTN)
- Security Tunnel Net 防溯源密网系统 – Anti traceability Network System (STN)
- 网络设备脆弱性测试分析系统 – Network Vulnerability Testing System
- Android 终端秘取平台 – Android Secret Extraction System
- Telegram 数据采集落查系统 – Telegram Data Collection System



เนื่องจากไม่มีหน้าเว็บหรือรายการสินค้าให้เลือกดูแล้วนั้นจึงทำให้อนุมานได้ว่าเครื่องมือพวกนี้ไม่ได้ถูกสร้างขึ้นมาเพื่อขายให้กับบุคคลทั่วไป อีกรายละเอียดที่น่าสนใจคือทางผู้สืบสวนได้พบสัญญาจัดซื้อจัดจ้างของกองทัพลดปล่อยประชาชนจีน (PLA) หลายฉบับที่ระบุชื่อบริษัทนี้เป็นผู้จัดจำหน่าย



ภาพที่ 2 เอกสารจัดซื้อจัดจ้างของ PLA (ที่มา intrusiontruth)



ความเชื่อมโยงระหว่าง RedRelay กับ Guangdong Chanming

จุดเชื่อมโยงของเครือข่ายฟร็อกซีนีกับบริษัทที่เป็นผู้ขายระบบ "Anonymous Network System" ให้กับหน่วยทหารในเขตไต้หวัน กรุงปักกิ่ง มีด้วยกันหลายจุด

1. ความเชื่อมโยงด้านตัวบุคคล: จากเอกสารการจดทะเบียนบริษัท บริษัท Guangdong Chanming ระบุผู้ถือหุ้นสองคน ได้แก่ ใต้ โจวจุน (代兆军) และหวัง ฮุยผิง (王慧平) จากการค้นหาข้อมูลเพิ่มเติมของผู้สอบสวน สามารถหาหมายเลขโทรศัพท์ของทั้งสองคนได้ คือ 13927279060 และ 13760865234 ตามลำดับ เมื่อติดตามหมายเลขโทรศัพท์ของหวัง ฮุยผิง ก็พบว่าหมายเลขนี้ปรากฏในข้อมูลรั่วไหลหลายครั้ง โดยจับคู่กับที่อยู่อีเมล boywhp@126[.]com ซ้ำๆ กัน และจากอีเมลนี้สามารถที่จะเชื่อมโยงไปยังบัญชี GitHub ที่ใช้ชื่อว่า boywhp ซึ่งเป็นเจ้าของ Repository เครื่องมือ FCN
- หมายเหตุ:** ข้อมูลเบอร์โทรและอีเมลที่ใช้เชื่อมโยงตัวตนดังกล่าวมาจากฐานข้อมูลรั่วไหล (breach data dumps) ซึ่งเป็นแหล่งข้อมูลที่มีข้อจำกัดด้านความถูกต้อง (อาจมีข้อมูลที่ล้าสมัย ผิดพลาด หรือถูกปลอมแปลง) จึงควรใช้ประกอบการวิเคราะห์ร่วมกับหลักฐานประเภทอื่น ไม่ควรใช้เป็นหลักฐานยืนยันตัวตนเพียงลำพัง



ภาพที่ 3 อีเมลและเบอร์โทรของ หวัง ฮุยผิง (ที่มา intrusiontruth)



- ความเชื่อมโยงด้านเครื่องมือ: จากเครื่องมือ FCN ที่พบนั้นจะมีการชี้ไปยัง Domain “xfconnect[.]com” และเมื่อตรวจสอบบน VirusTotal จะพบ Binaries ของ FCN หลายตัวซึ่งมีตัวที่มีความคล้ายคลึงกับเครื่องมือ STN ที่เป็นของบริษัท Guangdong Chanming อีกทั้ง String ที่ดึงออกมาจาก STN ก็ยังมีการกล่าวถึง FCN อีกด้วย



ภาพที่ 4 ภาพเปรียบเทียบโปรแกรมของ FCN และ STN (ที่มา intrusiontruth)

```
InternalName
HKEY_PERFORMANCE_DATA
ico/client.ico
wxVariantData
LC_MONETARY
PRC Envelope #7 Rotated 230 x 160 mm
seventeenth
ListView_Scroll(%d, %d) failed
@FcnUserConfig
Rep&lace
Windows cursor file
Can't save textctrl to file without filename.
file '%s', line %d: key '%s' was first found at line %d.
Module "%s" initialization failed
Failed to create the trollin '%c'
```

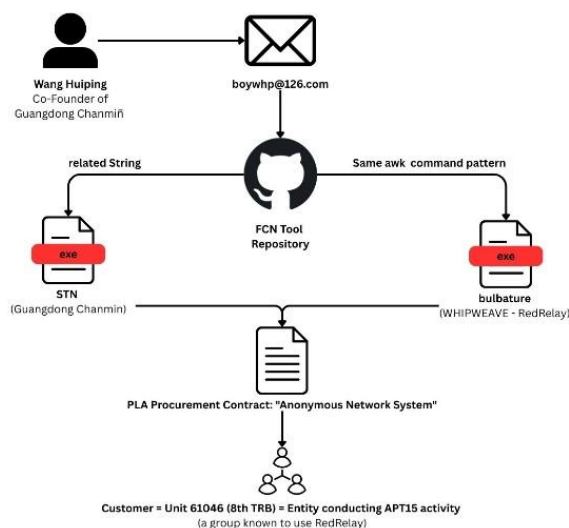
ภาพที่ 5 String ที่อ้างอิงถึง FCN จาก STN.exe

- ความเชื่อมโยงด้านเครื่องมือ: นอกจากความเชื่อมโยงของ FCN กับ STN แล้ว ผู้สืบสวนระบุว่าแทบทุกเวอร์ชันของ FCN บน Linux ใช้คำสั่งที่ผิดปกติอย่างมากในการระบุชื่ออินเทอร์เฟซ `cat /proc/net/route | awk '{print $1,$2}' | awk '/00000000/ {print $1}'` และคำสั่งนี้นำไปสู่ความเชื่อมโยงกับไฟล์ที่รู้จักกันในชื่อ `bulbature` หรือที่รู้จักกันในวงการว่าเป็น WHIPWEAVE ซึ่งถูกระบุโดยนักวิจัยว่าเป็นส่วนประกอบหลักของเครือข่าย RedRelay และ ORBWEAVER ซึ่งเป็นเครื่องมือที่ผู้ไม่หวังดีชาวจีนหลายรายใช้งาน ทั้งนี้หลักฐานที่ใช้เชื่อมโยง FCN เข้ากับ WHIPWEAVE เป็นการจับคู่ลายเซ็นคำสั่ง (command fingerprint) เพียงจุดเดียว ยังไม่ใช้การเปรียบเทียบซอร์สโค้ดทั้งหมดหรือ



การยืนยันว่าทั้งสองเป็นโปรแกรมเดียวกัน 100% จึงควรถือเป็นหลักฐานเชิงพฤติกรรมที่หนักแน่นแต่ยังเป็นทางอ้อม

4. ความเชื่อมโยงของสินค้าและผู้ซื้อ: จากการพบเอกสารจัดซื้อจัดจ้างของ PLA (PLAP) ที่ระบุว่า Guangdong Chanming จัดหา "Anonymous Network System" (ระบบเครือข่ายนิรนาม) ให้กับหน่วยทหารในเขตไห่เตี้ยน กรุงปักกิ่ง ซึ่งหากสมมติว่า RedRelay คือสินค้าที่ถูกขายจริง กลุ่ม APT ที่ใช้ RedRelay ก็ควรจะสอดคล้องกับรายชื่อลูกค้าของบริษัท การสืบสวนต่อมาพบเอกสาร eDiary ของหน่วยทหารจีนที่มีการอ้างถึง Unit 61046 ซึ่งสามารถระบุได้ว่าเป็น PLA Cyberspace Force 8th Technical Reconnaissance Base (8th TRB) และพบหลักฐานว่าหน่วยนี้เป็นผู้ดำเนินกิจกรรมของกลุ่ม APT15 ซึ่งเป็นกลุ่มที่ทราบกันจากแหล่งอื่นว่าใช้ RedRelay อย่างไรก็ตาม ผู้สืบสวนต้นทาง (Intrusion Truth) ระบุไว้อย่างชัดเจนว่าเอกสาร eDiary ฉบับนี้ไม่มีการกล่าวถึง RedRelay โดยตรงแต่อย่างใด และถือเป็นทางตัน (dead end) สำหรับการเชื่อมโยง Guangdong Chanming กับ RedRelay ในเชิงเอกสารโดยตรง ดังนั้นความเชื่อมโยงในข้อนี้จึงเป็นการอนุมานจากสองชุดหลักฐานที่แยกจากกัน (การใช้ RedRelay ของ APT15 จากแหล่งหนึ่ง และอัตลักษณ์ 8th TRB = APT15 จากอีกแหล่งหนึ่ง) ไม่ใช่หลักฐานเดียวที่เชื่อมโยงทั้งหมดเข้าด้วยกันโดยตรง



ภาพที่ 6 แผนภาพแสดงความเชื่อมโยงของเหตุการณ์



Tactics, Techniques, and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Resource Development	T1583.001	Acquire Infrastructure: Domains
	T1588.001	Obtain Capabilities: Malware
Discovery	T1016	System Network Configuration Discovery
Command and Control	T1090	Proxy
	T1090.003	Proxy: Multi-hop Proxy

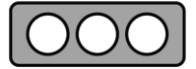


Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IoCs ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

ค่า IoC	คำอธิบาย
boywhp@126[.]com	อีเมลที่มีความเกี่ยวข้องกับหวัง ฮุยผิง เจ้าของ Repository ของ FCN
Xfconnect[.]com	โดเมนที่เครื่องมือ FCN มีการเชื่อมต่อไปหา
7b9aa96c19d342b9a352cac8e53b116edc92b871afca86b6b8d6ea834678f029	File hash ของ STN.exe
68ee37b260facbae2869b57c85471bce156726b69ebe8a90af400fedb188b143	File hash ของ FCN สำหรับ Windows
e9debb46c6a53a50ec17386852035d6a77cd2c065f2f71bf035d351dd5c827b1	File hash ของ FCN สำหรับ Windows
9c4c21f7dac9987962a06ef44a1d0ff95effcc61458f2c996392458db441a139	File hash ของ FCN สำหรับ Windows
936f4a73d27e5548789b284578a775254e78a3c48cf2119342aae870ec5e599d	File hash ของ FCN สำหรับ Windows
82d5e5325803220edce846e5b0b51556e80c8ee285dc3660b1b3996aa3440e53	File hash ของ FCN สำหรับ Windows
764d7be23a4db911255c7aa927b521b09e95d05a0941926863702995c74cd20c	File hash ของ FCN สำหรับ Windows
69c590cdd47494790301358e32eecb23e47dfba6a3d024e2c34b2bcec23eca16	File hash ของ FCN สำหรับ Windows
1bf39fd243216b1297b0c115dfcea4a2b25cb41d6ff14988fbb4473b448ab6e1	File hash ของ FCN สำหรับ Windows



df1d5e90fa719de71e655451de9131a84a 2e340028fec8bc163b578b38126ffa	File hash ของ FCN สำหรับ Android
629edf3dc98470604a8308b832763a1ef1 4514cbc0c194b0c34ec84f047488a1	File hash ของ FCN สำหรับ Android
f683539873ff5e514d02554efc6457a5fd6 e31bac0247e4bf9fc198cfb1e4aa7	File hash ของ FCN สำหรับ Android
a9ba8763d949375b348447375d8ee026d 18d0d5263d80b95a1e675a2110c27b6	File hash ของ FCN สำหรับ Android
b918500ef0d835c329f2d3d69edfbf5e71 e8be615d63c95ccde9f2815d1fcb6a	File hash ของ FCN สำหรับ Android



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- **ปรับกรอบความคิดจาก IOC แบบ static ไปสู่ Behavior-based Detection:** เนื่องจากโหนดของเครือข่าย ORB มีการหมุนเวียนเปลี่ยนแปลงอย่างรวดเร็ว (cycle) การพึ่งพา IP หรือโดเมนแบบ static เพียงอย่างเดียวจะไม่เพียงพอ ควรเน้นตรวจจับจากพฤติกรรม การเชื่อมต่อแทน เช่น รูปแบบการเชื่อมต่อ multi-hop, การเชื่อมต่อแบบเข้ารหัสไปยังปลายทางที่ไม่คุ้นเคย หรือช่วงเวลาการเชื่อมต่อที่ผิดปกติ
- **ตรวจสอบทราฟฟิกขาออก (Outbound Traffic) อย่างละเอียด:** ตั้งค่าระบบ Network Detection and Response (NDR) หรือ SIEM ให้ตรวจจับการเชื่อมต่อที่มีลักษณะ proxy/tunnel เช่น การเชื่อมต่อ TCP/TLS ที่มีระยะเวลานานผิดปกติ (long-lived connections), ปริมาณข้อมูลขาออกที่ไม่สอดคล้องกับพฤติกรรมการใช้งานปกติของ host นั้น หรือการเชื่อมต่อไปยัง ASN/cloud provider ที่ไม่เคยติดต่อมาก่อน
- **เฝ้าระวังอุปกรณ์ Edge Device เป็นพิเศษ:** เนื่องจากเครือข่าย ORB ประเภท Non-provisioned อาศัยอุปกรณ์ router/IoT ที่ถูกยึดครอง ควรเฝ้าระวังอุปกรณ์ edge (router, firewall, VPN gateway, IoT) เป็นกลุ่มเสี่ยงสูง โดยเฉพาะรุ่นที่หมดอายุการสนับสนุน (end-of-life) หรือมี firmware ล้าสมัย
- **ตรวจสอบพฤติกรรมการสำรวจเครือข่ายภายใน (Discovery Behavior):** เฝ้าระวังคำสั่งตรวจสอบ network interface/routing table ที่ผิดปกติบนระบบ Linux/Unix (เช่น การอ่านค่าจาก /proc/net/route ในรูปแบบสคริปต์อัตโนมัติ) ซึ่งเป็นพฤติกรรมทั่วไปของมัลแวร์ตระกูล tunneling ที่ใช้เชื่อมต่อเข้าเครือข่าย ORB

การป้องกัน (Prevention)

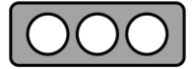
- **จำกัดและควบคุมทราฟฟิกขาออก (Egress Filtering):** กำหนดนโยบาย allowlist สำหรับปลายทางที่จำเป็นต่อการดำเนินธุรกิจ แทนการอนุญาตทราฟฟิกขาออกแบบเปิดกว้าง (default-allow) เพื่อลดโอกาสที่มัลแวร์ tunneling จะสร้างช่องทางออกไปยัง relay node ได้สำเร็จ
- **ปิดกั้นหรือจำกัดโปรโตคอลที่ใช้สำหรับการทำ proxy/tunnel ที่ไม่จำเป็น:** ตรวจสอบและปิดพอร์ต/บริการที่ไม่ได้ใช้งานจริงบน edge device พร้อมทั้งจำกัดการใช้งาน SOCKS proxy, VPN client ที่ไม่ได้รับอนุญาตในองค์กร



- **ปรับปรุงและแพตช์อุปกรณ์ Edge Device อย่างสม่ำเสมอ:** เนื่องจากอุปกรณ์เหล่านี้เป็นเป้าหมายหลักในการถูกยึดครองเข้าร่วมเครือข่าย ORB ประเภท non-provisioned ควรมีการอัปเดต firmware/patch อย่างสม่ำเสมอ และพิจารณาปลดระวางอุปกรณ์ที่หมดอายุการสนับสนุน (EOL) แทนที่ด้วยรุ่นที่ยังได้รับการดูแล
- **บังคับใช้ Network Segmentation:** แบ่งแยกเครือข่ายภายในเป็นส่วนย่อย (segmentation) เพื่อจำกัดความสามารถของผู้โจมตีในการใช้อุปกรณ์ที่ถูกยึดครองเป็นจุดกระโดดต่อ (pivot point) ไปยังระบบสำคัญอื่นๆ
- **ใช้การยืนยันตัวตนแบบหลายปัจจัย (MFA) และหลักการสิทธิ์ขั้นต่ำ (Least Privilege):** เพื่อลดผลกระทบหากมีการเข้าถึงผ่านช่องทาง relay/proxy ที่ปกปิดตัวตนได้สำเร็จ

การรับมือ (Response)

- **แยกอุปกรณ์ที่ติดเชื้อ:** หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อเครื่องที่มีการบุกรุกนั้นออกจากเครือข่ายเพื่อป้องกันการแพร่กระจาย
- **เก็บหลักฐานทางดิจิทัลก่อนทำการแก้ไข (Forensic Preservation):** จัดเก็บ memory dump, network logs, และ configuration ของอุปกรณ์ที่ต้องสงสัยก่อนทำการ reset หรือ reimage เนื่องจากมัลแวร์ tunneling บางตัวอาจไม่ทิ้งร่องรอยถาวรบนดิสก์
- **ตรวจสอบขอบเขตผลกระทบ (Scope Assessment):** เนื่องจากเครือข่าย ORB มักถูกใช้เป็นเพียงชั้นหนึ่งของการโจมตีที่ซับซ้อนกว่านั้น (เช่น ใช้เพื่อปกปิดการเข้าถึงเบื้องหลัง) การพบทราฟฟิกที่เชื่อมโยงกับ ORB ควรถือเป็นสัญญาณเตือนให้ตรวจสอบระบบที่เกี่ยวข้องอย่างละเอียดเพิ่มเติม ไม่ใช่ปิดเคสเพียงแคปิดกั้น IP ที่พบ
- **พิจารณาว่า IOC ที่เกี่ยวข้องกับ ORB มีอายุการใช้งานสั้น:** หลังบล็อกโหนดที่พบแล้ว ควรตรวจสอบซ้ำเป็นระยะเนื่องจากโครงสร้างพื้นฐานของเครือข่าย ORB มีการหมุนเวียนเปลี่ยนโหนดอย่างรวดเร็ว การบล็อก IOC ชุดเดิมอาจไม่มีประสิทธิภาพในระยะยาว
- **แจ้งเตือนและประสานงานกับหน่วยงานที่เกี่ยวข้อง:** รายงานเหตุการณ์ไปยังหน่วยงาน CERT/CSIRT ที่เกี่ยวข้องกับหน่วยงานนั้น ๆ



อ้างอิง (References)

1. Intrusiontruth's blog "Dear Diary, Today I found a Ghost in the Network"
<https://intrusiontruth.wordpress.com/2026/07/27/dear-diary-today-i-found-a-ghost-in-the-network/>
2. Intrusiontruth's blog "Turns out the Ghost was the PLA"
<https://intrusiontruth.wordpress.com/2026/07/28/turns-out-the-ghost-was-the-pla/>
3. Google Cloud's Blog "IOC Extinction? China-Nexus Cyber Espionage Actors Use ORB Networks to Raise Cost on Defenders"
<https://cloud.google.com/blog/topics/threat-intelligence/china-nexus-espionage-orb-networks>
4. PwC's Threat Intelligence Report 2022 "Cyber Threats 2022 Year in Retrospect"
<https://www.pwc.at/de/dienstleistungen/Cyber/2022-year-in-retrospect-report.pdf>
5. Symantec's Threat Intelligence "Cloud Cover: How Malicious Actors Are Leveraging Cloud Services"
<https://www.security.com/threat-intelligence/cloud-espionage-attacks>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://forms.gle/4QikxjAfRtsHogsn8>



จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th